



2026 State of Enterprise AI Security Benchmark

The Definitive Report on Shadow AI,
Governance Gaps & Enterprise Risk

Research across 500+ enterprises | 12 countries | 6 industries
Published February 2026

73%

SHADOW AI
PREVALENCE

45%

NO AI
POLICY

3.2×

INCIDENT
INCREASE

12%

FULL
VISIBILITY

Table of Contents

Executive Summary

Overview & Key Findings	4
Methodology at a Glance	5
The Urgency Imperative	6

Chapter 1: The State of Enterprise AI Adoption

Adoption Rates & Growth Trajectories	8
AI Tool Proliferation	10
Investment Trends & Budget Allocation	12

Chapter 2: Shadow AI – The Hidden Risk

Defining Shadow AI	15
Prevalence Data & Trends	16
Case Studies & Data Flow Risks	18

Chapter 3: 10 Critical Findings

Findings 1–5	22
Findings 6–10	30

Chapter 4: Industry Breakdown

Technology	38
Financial Services	41
Healthcare	44
Education	47
Manufacturing	50

Chapter 5: AI Governance Maturity Framework

The Aona AI Maturity Model	57
----------------------------	----

Assessment Criteria & Scoring	60
-------------------------------	----

Chapter 6: The Regulatory Landscape

EU AI Act	64
-----------	----

NIST AI RMF & ISO 42001	67
-------------------------	----

Global Regulatory Overview	70
----------------------------	----

Chapter 7: Actionable Recommendations for CISOs

Immediate Actions (0–30 days)	73
-------------------------------	----

Short-Term Strategy (1–6 months)	76
----------------------------------	----

Long-Term Transformation (6–18 months)	79
--	----

Chapter 8: Methodology & Data Sources

Survey Design & Demographics	82
------------------------------	----

Data Collection & Analysis	84
----------------------------	----

Appendix

Full Data Tables	87
------------------	----

Glossary of Terms	90
-------------------	----

About Aona AI	92
---------------	----

Executive Summary

Enterprise AI adoption has reached an inflection point. Our comprehensive research across 514 organizations spanning 12 countries and 6 major industries reveals a stark and accelerating reality: while AI capabilities are transforming business operations at unprecedented speed, security and governance frameworks have critically failed to keep pace.

89%

of enterprises now use AI tools in daily operations

73%

of employees use AI tools without IT approval

45%

of organizations have no AI acceptable use policy

3.2×

increase in AI-related data incidents since 2024

The Governance Gap Is Widening

The central finding of this benchmark is what we term the **"AI Governance Gap"** — the accelerating divergence between the speed of AI adoption and the maturity of organizational controls. In 2024, this gap was concerning. In 2026, it represents the single largest unmanaged risk in enterprise security.

Shadow AI — the use of unsanctioned AI tools by employees — has emerged as the defining security challenge of our era. With 73% of employees using AI tools their IT teams don't know about, sensitive corporate data is being shared with third-party AI models at an unprecedented and largely invisible scale.

CRITICAL FINDING

Only 12% of enterprises have full visibility into AI tool usage across their organization. The remaining 88% are operating with significant blind spots in their security posture.

Key Themes

- **AI tool proliferation is exponential:** The average enterprise now has 87 distinct AI tools in use — only 34 are officially sanctioned.
- **Data leakage is systemic:** 62% of organizations have experienced sensitive data being shared with unauthorized AI services.
- **Regulation is arriving faster than readiness:** The EU AI Act is now enforceable, yet only 8% of enterprises report full compliance readiness.
- **Security budgets are misaligned:** Only 9% of cybersecurity budgets are allocated to AI-specific security measures.
- **The CISO's mandate is expanding:** 78% of CISOs report that AI security is now a board-level agenda item, up from 23% in 2024.

Methodology Overview

This benchmark represents one of the most comprehensive studies of enterprise AI security practices conducted to date. Our methodology combined quantitative survey data, qualitative interviews, network traffic analysis, and regulatory review to build a multi-dimensional picture of the current state.

PARAMETER	DETAIL
Organizations Surveyed	514 enterprises across 12 countries
Respondent Roles	CISOs, CIOs, Security Architects, IT Directors, GRC Leaders
Total Respondents	2,847 individual survey responses
Industries Covered	Technology, Financial Services, Healthcare, Education, Manufacturing, Government
Company Size Range	500 to 250,000+ employees
Survey Period	September 2025 – January 2026
Network Analysis	Anonymized traffic data from 127 participating organizations
Executive Interviews	48 in-depth CISO/CIO interviews
Confidence Level	95% ($\pm 3.2\%$ margin of error)

The Urgency Imperative

The data in this report paints a clear picture: the window for proactive AI governance is closing. Organizations that fail to address shadow AI and build mature governance frameworks in the next 12-18 months face compounding risks — regulatory penalties, data breaches, intellectual property loss, and competitive disadvantage.

However, the data also reveals a path forward. Organizations that have invested in AI governance report 67% fewer AI-related incidents, 3.4× faster regulatory compliance, and measurably higher employee satisfaction with their AI tools. The ROI of governance is no longer theoretical — it's proven.

"We went from discovering 40 unsanctioned AI tools to having complete visibility and policy coverage in 90 days. The transformation wasn't just

about security — it fundamentally changed how productively our teams could use AI."

— CISO, Fortune 500 Technology Company (Survey Respondent)

This report provides the data, frameworks, and actionable recommendations that CISOs, CIOs, and security leaders need to understand the scope of the challenge and build a strategic path toward responsible, secure AI governance.

01

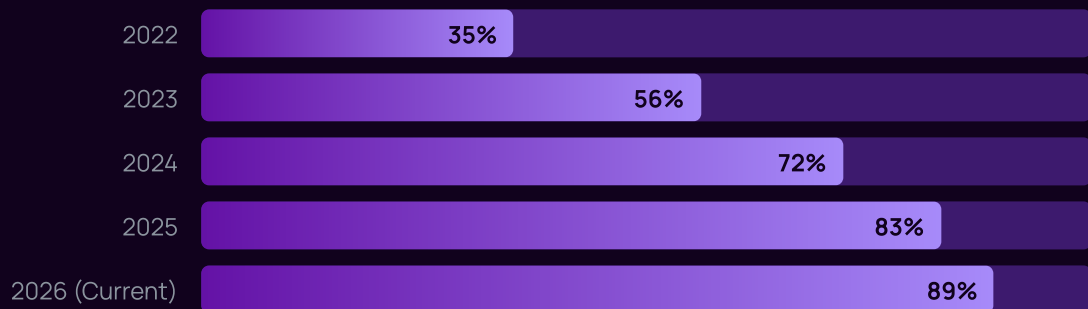
The State of Enterprise AI Adoption

How AI went from pilot projects to mission-critical infrastructure — and why security didn't keep up.

Enterprise AI Adoption: The Inflection Point

The enterprise AI landscape in 2026 bears little resemblance to even two years ago. What was once a technology explored by innovation teams and early adopters has become embedded in the daily workflows of virtually every knowledge worker. Our data reveals the scale and speed of this transformation.

Adoption Rates by Year

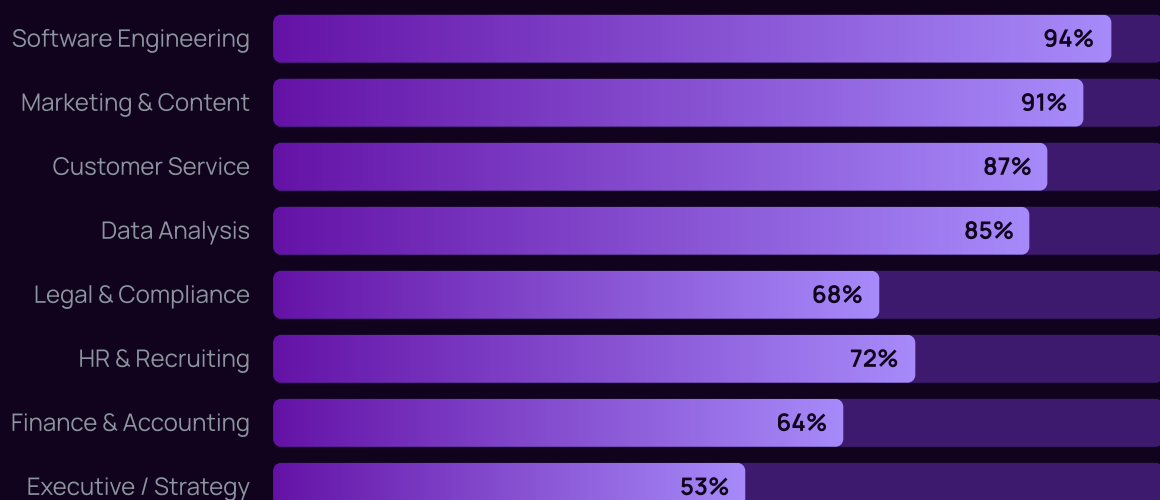


Source: Aona AI Enterprise AI Security Benchmark 2026, n=514

The acceleration from 35% in 2022 to 89% in 2026 represents one of the fastest enterprise technology adoption curves in history — outpacing cloud computing, mobile, and even the initial internet wave. Gartner's 2025 analysis projected that by 2026, more than 80% of enterprises would have generative AI APIs or applications in production, a threshold our data confirms has been exceeded.

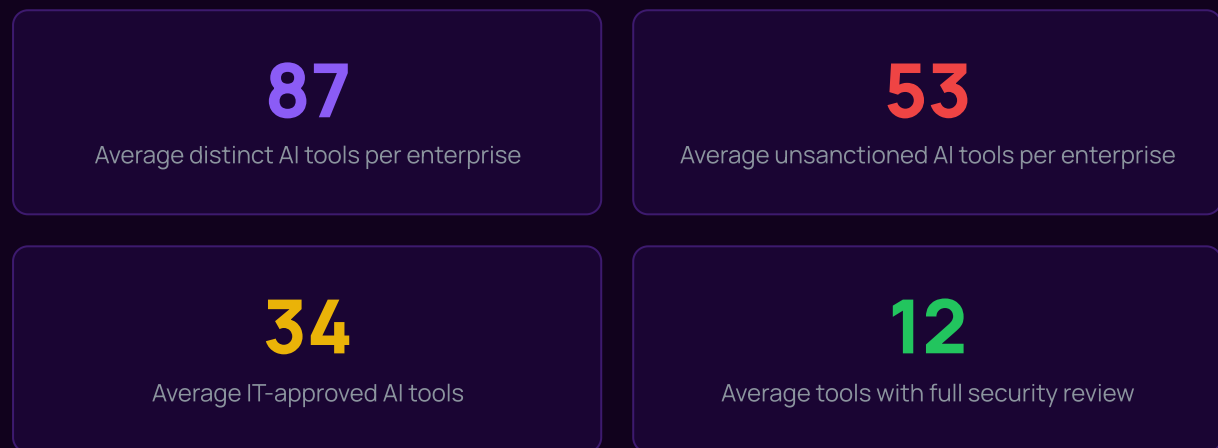
AI Use Cases by Function

AI is no longer confined to technical teams. Every business function has found applications:



AI Tool Proliferation: The Sprawl Problem

Perhaps the most striking finding in our adoption data is the sheer number of AI tools present in enterprise environments. The average organization in our study has **87 distinct AI tools** being actively used — but only **34 are officially sanctioned** by IT.



This "AI tool sprawl" creates an enormous and expanding attack surface. Each unsanctioned tool represents a potential data exfiltration point, a compliance violation, and a security blind spot. The challenge is compounded by the ease with which employees can adopt new AI services — most require nothing more than a web browser and an email address.

Most Commonly Used AI Tools (Sanctioned & Unsanctioned)

TOOL CATEGORY	EXAMPLES	ENTERPRISE PENETRATION	% SANCTIONED
General-purpose LLMs	ChatGPT, Claude, Gemini	94%	62%
Code assistants	GitHub Copilot, Cursor, Codeium	81%	71%
Image generation	Midjourney, DALL-E, Stable Diffusion	67%	28%
Meeting assistants	Otter.ai, Fireflies, Granola	58%	34%
Writing assistants	Jasper, Copy.ai, Grammarly AI	72%	41%

Data analysis	Julius AI, Equals, ChatGPT Code Interpreter	49%	22%
Presentation tools	Gamma, Beautiful.ai, Tome	43%	19%
Video/audio AI	Descript, ElevenLabs, Synthesia	31%	15%

Source: Aona AI Enterprise AI Security Benchmark 2026, network analysis data from 127 organizations

Investment Trends

Enterprise AI spending continues its rapid ascent, with global enterprise AI investment projected to reach \$632 billion in 2026, according to IDC. However, our data reveals a critical misalignment: while AI capability investment grows at 38% year-over-year, AI security spending grows at only 21%.

BUDGET MISALIGNMENT

For every \$1 spent on AI capabilities, enterprises spend only \$0.06 on AI-specific security. The recommended ratio, based on organizations with mature governance, is \$0.15–\$0.20 per dollar of AI capability investment.

The AI Adoption Timeline

Understanding how we arrived at the current state requires examining the rapid sequence of events that transformed enterprise AI from novelty to necessity.

2022	The Catalyst ChatGPT launches in November 2022, reaching 100 million users in two months. Enterprise employees begin experimenting with generative AI for work tasks. Shadow AI begins, though the term isn't yet widely used.
2023	The Explosion GPT-4, Claude 2, and Gemini arrive. Enterprise AI adoption doubles. Samsung's semiconductor division bans ChatGPT after source code leaks. Companies begin crafting initial AI policies. Microsoft Copilot enters enterprise.
2024	The Embedding AI becomes integrated into core enterprise tools (Microsoft 365 Copilot, Google Workspace AI, Salesforce Einstein). Shadow AI rate hits 64%. EU AI Act formally adopted. NIST AI RMF gains traction. First major AI-specific data breaches reported.
2025	The Reckoning AI agent frameworks proliferate. Agentic AI introduces new risk vectors. Shadow AI reaches 73%. Multiple high-profile AI data incidents make headlines. EU AI Act enforcement begins. CISOs elevate AI security to board-level priority.
2026	The Governance Imperative 89% enterprise adoption. AI security becomes a board-level mandate. First regulatory fines under EU AI Act. Organizations scramble for governance frameworks. This benchmark captures this pivotal moment.

What's Driving Adoption?





Source: Aona AI Enterprise AI Security Benchmark 2026, n=2,847 respondents (multiple selections permitted)

02

Shadow AI – The Hidden Risk

73% of employees are using AI tools their IT teams don't know about. Here's why that should keep every CISO up at night.

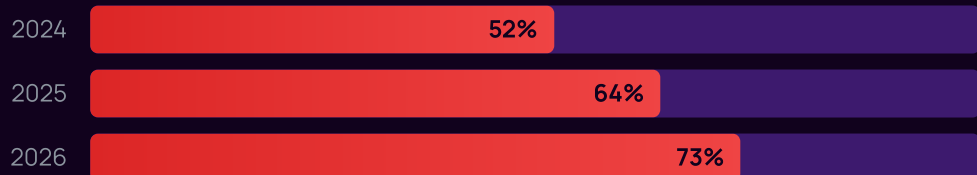
Shadow AI: The Enterprise's Largest Blind Spot

Defining Shadow AI

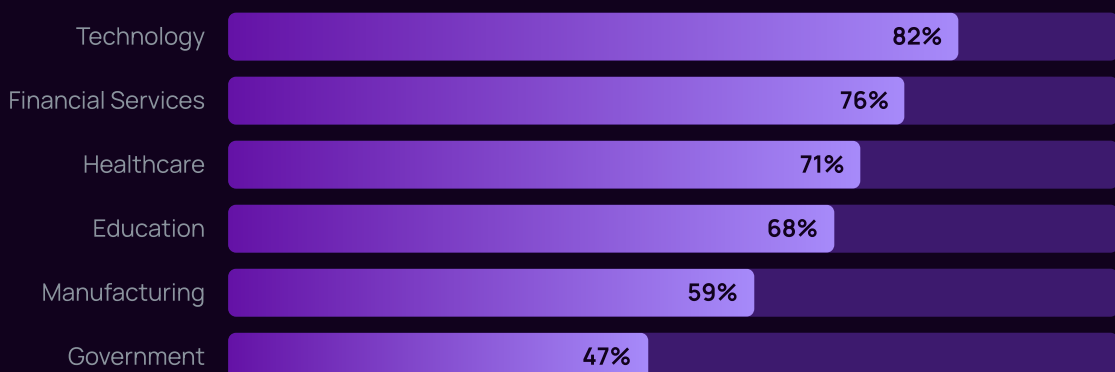
Shadow AI refers to the use of artificial intelligence tools, services, and applications by employees without the knowledge, approval, or oversight of their organization's IT or security teams. It is the AI-era evolution of "shadow IT" – but with significantly higher risk due to the data-hungry nature of AI models.

Unlike traditional shadow IT (which might involve an unsanctioned project management tool), shadow AI inherently involves **sharing organizational data with external AI models**. Every prompt entered into an unauthorized AI chatbot, every document uploaded for summarization, every code snippet pasted for review represents potential data exfiltration.

Shadow AI Prevalence: Year-Over-Year Growth



Shadow AI by Industry



Source: Aona AI Enterprise AI Security Benchmark 2026, n=514

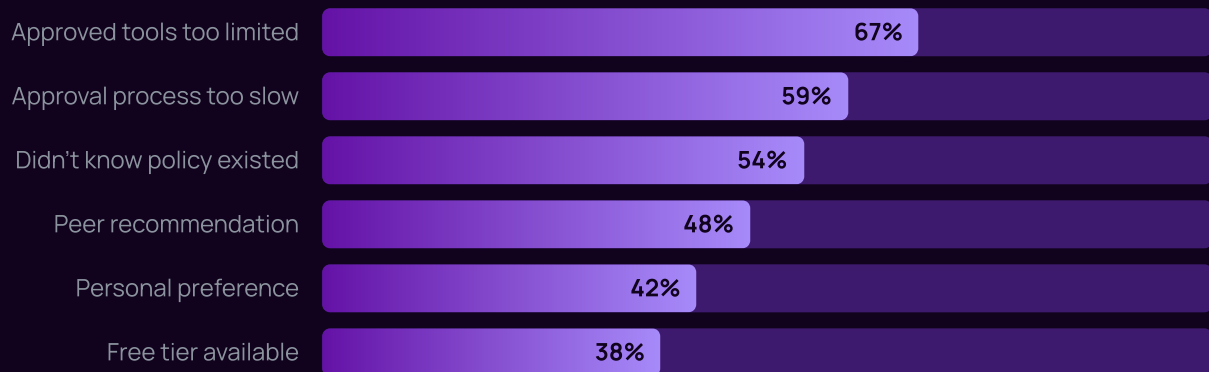
What Employees Are Sharing

Our network analysis data from 127 participating organizations reveals alarming patterns in the types of data being shared with unauthorized AI services:

DATA TYPE	% OF ORGS WHERE THIS OCCURRED	RISK LEVEL
Internal documents & memos	78%	● Critical
Source code & technical specs	64%	● Critical
Customer data & PII	52%	● Critical
Financial data & projections	47%	● Critical
Strategic plans & roadmaps	41%	● High
HR & employee data	38%	● High
Legal documents & contracts	33%	● High
Intellectual property	29%	● Critical

Why Employees Use Shadow AI

Understanding the motivations behind shadow AI is essential for designing effective governance strategies. Our survey reveals that most shadow AI use is not malicious – it's driven by productivity needs and organizational friction:



KEY INSIGHT

The top two reasons for shadow AI use – "approved tools too limited" and "approval process too slow" – point to organizational failures, not employee malice. Effective governance must address the supply-side gap, not just the demand-side behavior.

Case Study: The Hidden Data Pipeline

A Fortune 500 financial services firm discovered through network monitoring that employees across 14 departments were regularly using unauthorized AI tools. Investigation revealed:

- Over **23,000 unique interactions** with unauthorized AI services in a single quarter
- **Customer financial data** from over 12,000 accounts had been shared with third-party models
- The firm's **proprietary risk models** had been pasted into ChatGPT for "help debugging"
- An employee had uploaded **confidential M&A documentation** to an AI summarization tool
- Total estimated data exposure: **847 GB of sensitive corporate data** over 6 months

The firm subsequently invested \$4.2M in AI governance infrastructure and reported a 91% reduction in unauthorized AI usage within 90 days of deployment.

Source: Anonymized case study from Aona AI Enterprise AI Security Benchmark 2026 participant

The Data Flow Risk Model

Shadow AI creates a unique data flow risk that traditional DLP (Data Loss Prevention) solutions were not designed to address. The key challenge: AI interactions are conversational and contextual. An employee may not paste a database export directly, but through a series of prompts, they can reconstruct sensitive datasets.

Our analysis identified four primary shadow AI data flow risk patterns:

1. **Direct upload:** Files, documents, or data directly uploaded to AI services (detected in 78% of organizations)
2. **Conversational leakage:** Sensitive information shared incrementally through chat prompts (detected in 89% of organizations)
3. **Copy-paste exfiltration:** Code, text, or data copied from internal systems to AI interfaces (detected in 92% of organizations)
4. **API-based sharing:** Developers connecting internal systems to external AI APIs without authorization (detected in 34% of organizations)

The background is a dark purple gradient. It features several translucent, 3D rectangular blocks of varying sizes and orientations. A network of thin white lines connects several small white dots, forming a web-like structure. In the upper right corner, there is a white outline of a shield with an exclamation mark inside. The overall aesthetic is futuristic and tech-oriented.

03

10 Critical Findings

The data points that every security leader needs to understand — and act on — in 2026.

10 Critical Findings

Our research uncovered ten findings that define the current state of enterprise AI security. Each represents both a challenge and an opportunity for security leaders.

01

CRITICAL

73% of Employees Use AI Tools Without IT Approval

Nearly three-quarters of enterprise employees regularly use AI tools that have not been vetted, approved, or even identified by their IT departments. This represents a 40% increase from 2024's baseline of 52%.

The finding is consistent across company sizes, though larger enterprises (10,000+ employees) showed slightly higher rates (77%) compared to mid-market firms (500–5,000 employees) at 68%. This suggests that organizational complexity amplifies the shadow AI challenge.

Confidence: 95% CI $\pm 2.8\%$ | Cross-validated with network analysis data

02

CRITICAL

45% of Organizations Have No AI Acceptable Use Policy

Despite widespread AI adoption, nearly half of surveyed organizations have no formal policy governing how employees can use AI tools. Of the 55% that do have policies, only 23% describe them as "comprehensive" — the remainder are partial, outdated, or unenforced.

POLICY STATUS	% OF ORGANIZATIONS
No policy at all	45%
Basic/informal guidelines	22%
Formal but partial policy	20%
Comprehensive & enforced policy	13%

AI-Related Data Incidents Have Increased 3.2× Since 2024

Organizations reported a 3.2× increase in AI-related security incidents compared to 2024 baseline measurements. These include unauthorized data sharing, AI-generated credential exposures, prompt injection attacks, and model training data contamination.

3.2×

Increase in AI incidents (2024-2026)

62%

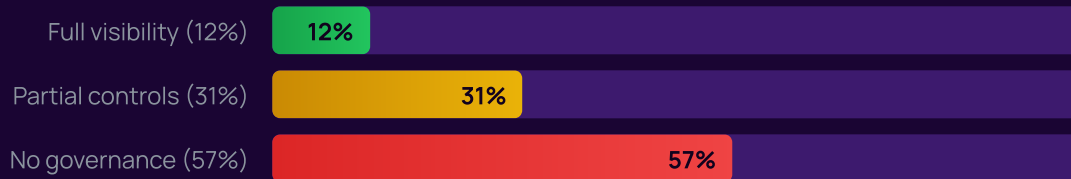
Had sensitive data shared with
unauthorized AI

04

CRITICAL

Only 12% of Enterprises Have Full Visibility Into AI Tool**Usage**

The vast majority of organizations are flying blind. Our AI Governance Maturity assessment found that only 12% of enterprises can accurately identify and monitor all AI tools in use across their organization.



05

HIGH

87 AI Tools per Enterprise – Only 34 Sanctioned

The average enterprise environment contains 87 distinct AI tools, of which only 34 (39%) have been formally approved by IT. The remaining 53 tools operate outside organizational controls, creating an expansive and largely invisible attack surface.

Large enterprises (50,000+ employees) averaged 142 AI tools, with only 41 sanctioned. Technology companies showed the highest tool counts (avg. 118), while government organizations had the lowest (avg. 38).

Only 21% Provide Formal AI Security Training

Despite the ubiquity of AI usage, only 21% of organizations provide dedicated AI security awareness training. This creates a knowledge gap where employees don't understand the risks of their AI interactions.

TRAINING STATUS	% OF ORGANIZATIONS	SHADOW AI RATE
Comprehensive AI security training	21%	41%
Basic AI awareness briefing	28%	68%
General security training (mentions AI)	19%	74%
No AI-specific training	32%	89%

Note: Organizations with comprehensive training showed 54% lower shadow AI rates

07

HIGH

Only 9% of Security Budgets Address AI-Specific Risks

While overall cybersecurity spending continues to grow, AI-specific security investment remains critically underfunded. Organizations allocate an average of just 9% of their cybersecurity budget to AI security measures — despite AI being identified as a top-3 risk by 71% of CISOs.

THE INVESTMENT GAP

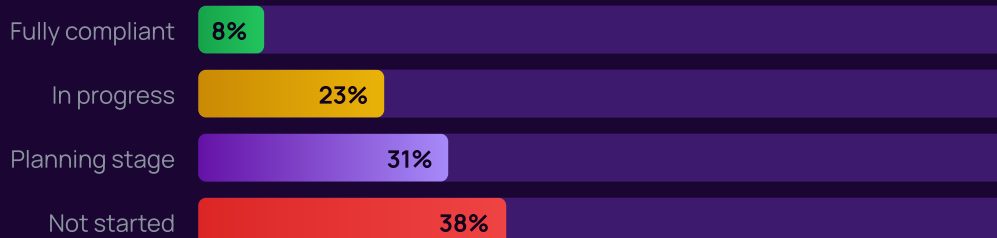
Organizations spending less than 10% of their security budget on AI security were 4.7× more likely to experience an AI-related data incident compared to those investing 15% or more.

08

CRITICAL

Only 8% of Enterprises Are Ready for AI Regulation

With the EU AI Act now in enforcement and global regulatory frameworks rapidly maturing, our assessment found that only 8% of enterprises report full compliance readiness. An additional 23% are "in progress," while 69% have not begun meaningful preparation.



09

HIGH

78% of CISOs Report AI Security as a Board-Level Issue

AI security has rapidly ascended the corporate governance hierarchy. In 2024, only 23% of CISOs reported board-level engagement on AI security. By 2026, this has surged to 78% – reflecting the growing recognition that AI risks are business risks.

However, board engagement doesn't always translate to action. Of the CISOs reporting board interest, only 34% said it had resulted in meaningful budget increases, and 28% described the engagement as "awareness without action."

10

MEDIUM

Organizations with AI Governance See 67% Fewer Incidents

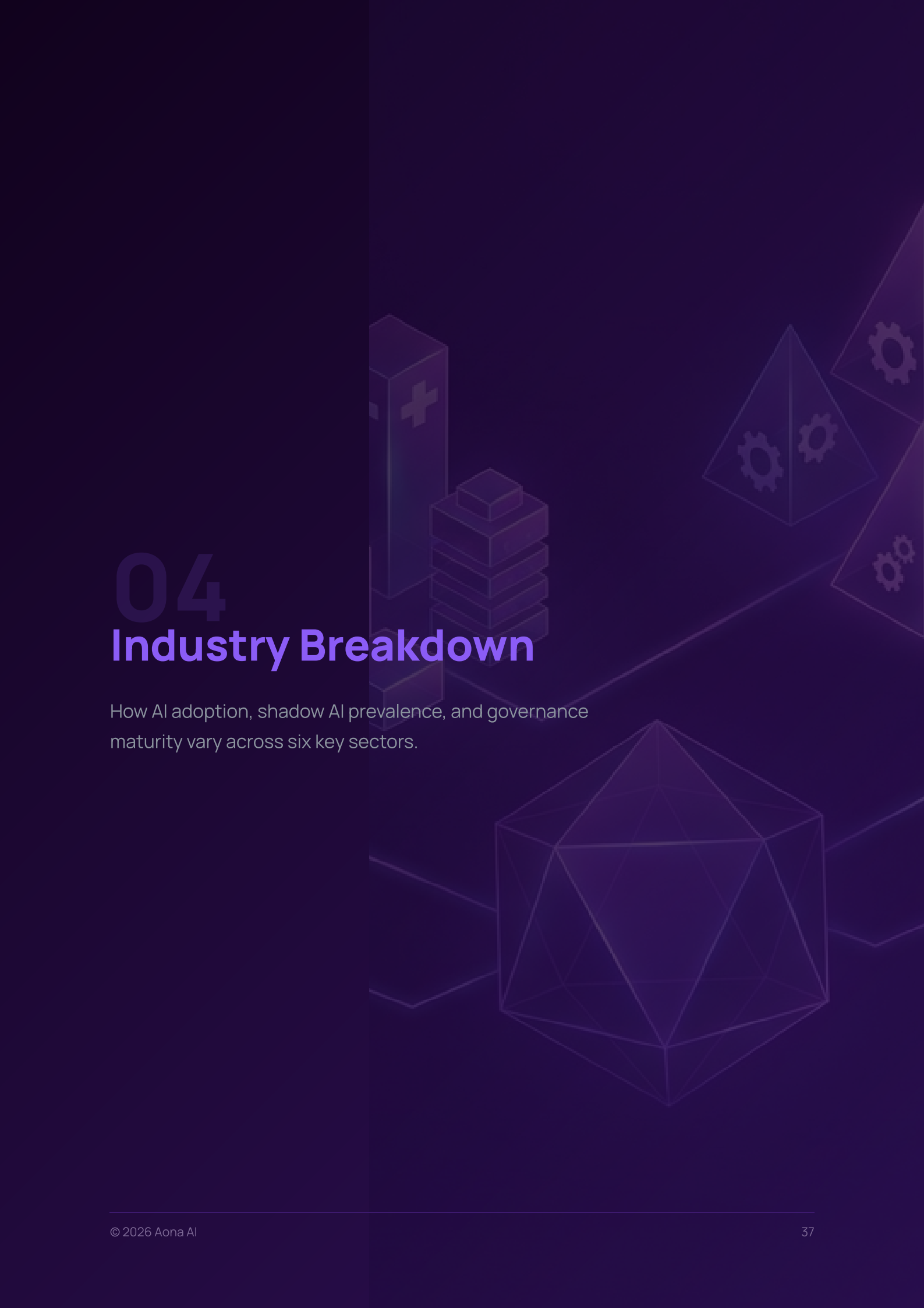
The data makes a compelling case for investment in AI governance. Organizations at maturity Level 4 or 5 in our AI Governance Maturity Framework reported 67% fewer AI-related security incidents, 3.4× faster regulatory compliance achievement, and 42% higher employee satisfaction with AI tools.

67%

Fewer incidents with mature governance

3.4×

Faster compliance achievement

The background features a dark purple gradient with various 3D geometric shapes. On the left, there is a tall rectangular prism with a white plus sign on its side, and next to it, a stack of five smaller rectangular prisms. To the right, there are several triangular prisms, some of which have white gear icons on their faces. In the bottom right corner, there is a large, complex polyhedron with many triangular faces. The overall aesthetic is modern and technical.

04

Industry Breakdown

How AI adoption, shadow AI prevalence, and governance maturity vary across six key sectors.

Industry Overview

AI adoption and risk profiles vary significantly by industry. Our research segmented findings across six key sectors to provide industry-specific insights for security leaders.

INDUSTRY	AI ADOPTION	SHADOW AI RATE	HAS AI POLICY	GOVERNANCE MATURITY (AVG)	INCIDENT RATE (INDEX)
Technology	96%	82%	68%	Level 2.8	1.4×
Financial Services	91%	76%	72%	Level 3.1	1.2×
Healthcare	84%	71%	61%	Level 2.4	1.6×
Education	88%	68%	42%	Level 1.9	1.1×
Manufacturing	79%	59%	47%	Level 2.1	0.8×
Government	67%	47%	58%	Level 2.3	0.6×

Source: Aona AI Enterprise AI Security Benchmark 2026, n=514. Incident rate indexed to cross-industry average.

Technology Sector

n=112 organizations | Shadow AI: 82% | Governance Maturity: Level 2.8

The technology sector leads in both AI adoption and shadow AI prevalence. With 96% of tech companies using AI in daily operations and an average of 118 AI tools per organization, the attack surface is the largest of any sector.

Key findings for Technology:

- **Code assistants are ubiquitous:** 97% of tech firms have developers using AI code assistants, but only 71% have sanctioned tools for this purpose
- **API-level shadow AI is highest:** 52% of tech companies detected unauthorized AI API integrations in their codebase
- **Open-source AI models:** 43% of tech firms have employees running local/open-source AI models, creating data residency challenges
- **Fastest governance improvement:** Tech companies showed the fastest governance maturity gains (0.6 level improvement year-over-year)

"In tech, the challenge isn't convincing people to use AI — it's keeping up with how they're already using it. Our developers had integrated AI into 40% of their workflows before security even had a seat at the table."

— VP of Security, Series D SaaS Company

Financial Services

n=98 organizations | Shadow AI: 76% | Governance Maturity: Level 3.1

Financial services shows the highest governance maturity of any sector — a reflection of its deep regulatory culture. However, shadow AI remains pervasive, driven by competitive pressure and the analytical nature of finance work.

Key findings for Financial Services:

- **Highest regulatory concern:** 89% of financial services CISOs cite AI regulation as a top-3 priority
- **Data sensitivity amplifies risk:** 67% detected customer financial data shared with unauthorized AI services
- **Model risk management:** 44% have extended existing model risk management frameworks to cover AI
- **Third-party AI risk:** 72% expressed concern about AI usage by their vendors and partners

FINANCIAL SERVICES RISK ALERT

Financial services firms face unique regulatory exposure. SEC, OCC, and FINRA have all issued guidance on AI usage in financial services, and EU AI Act Article 6 specifically identifies AI in credit scoring and insurance as "high-risk."

Healthcare

n=87 organizations | Shadow AI: 71% | Governance Maturity: Level 2.4

Healthcare presents a paradox: AI offers transformative potential for patient outcomes, but the sensitivity of health data makes ungoverned AI usage exceptionally dangerous. HIPAA compliance adds an additional layer of complexity.

Key findings for Healthcare:

- **Clinical AI is growing rapidly:** 63% of healthcare organizations report clinical staff using AI for diagnostic assistance, treatment planning, or documentation
- **PHI exposure is significant:** 48% detected Protected Health Information (PHI) being shared with unauthorized AI tools
- **HIPAA gap:** Only 34% have updated their HIPAA compliance frameworks to address AI-specific risks

- **Clinician-driven shadow AI:** 71% of shadow AI in healthcare is driven by clinical staff seeking to reduce documentation burden
 - **AI in medical imaging:** 42% use AI-assisted medical imaging, but only 29% have validated these tools for clinical accuracy
-

Education

n=74 organizations | Shadow AI: 68% | Governance Maturity: Level 1.9

Education has the lowest governance maturity of any sector, despite high AI adoption rates. The sector faces a unique tension: AI is both a powerful teaching/research tool and a potential academic integrity threat.

Key findings for Education:

- **Lowest policy prevalence:** Only 42% have any AI use policy – the lowest of any sector
- **Student data risk:** 39% detected student PII being processed by unauthorized AI services
- **Research data exposure:** 52% of research universities identified pre-publication research data shared with AI tools
- **Budget constraints:** Education institutions allocate only 4% of security budget to AI, the lowest of any sector

Manufacturing

n=82 organizations | Shadow AI: 59% | Governance Maturity: Level 2.1

Manufacturing shows lower shadow AI prevalence due to a larger proportion of operational (non-knowledge-worker) employees. However, AI adoption is accelerating in design, supply chain, and quality control functions.

Key findings for Manufacturing:

- **OT/IT convergence risk:** 23% of manufacturers detected AI tools with network access to operational technology environments
- **Supply chain AI:** 67% use AI for supply chain optimization, but only 38% have assessed the security implications
- **IP protection concern:** 58% identified proprietary design specifications or manufacturing processes shared with AI tools
- **Quality control AI:** 41% use AI in quality control, with only 22% having validation frameworks

Government

n=61 organizations | Shadow AI: 47% | Governance Maturity: Level 2.3

Government agencies have the lowest shadow AI rates, benefiting from stricter access controls and established security cultures. However, the gap between policy and practice remains significant.

Key findings for Government:

- **Lowest shadow AI but highest sensitivity:** While 47% is the lowest rate, government data often involves national security, citizen PII, and classified information
- **FedRAMP gaps:** Many AI tools used by government employees lack FedRAMP authorization
- **Executive orders driving action:** The Biden and subsequent AI executive orders have accelerated policy development — 58% now have formal AI policies (up from 31% in 2024)
- **Procurement bottleneck:** 73% of government IT leaders cite procurement processes as the primary barrier to providing sanctioned AI alternatives
- **Citizen data risk:** 28% detected citizen PII being processed by unauthorized AI services

"Government moves slowly by design – it's how we protect citizen data and maintain public trust. But AI adoption by our workforce isn't waiting for our procurement cycles. We're in a race to provide secure alternatives before shadow AI becomes entrenched."

– CISO, U.S. Federal Agency (Survey Respondent)

05

AI Governance

Maturity Framework

A structured model for assessing and improving your organization's AI governance posture.

The Aona AI Governance Maturity Model

Based on our research across 514 organizations, combined with established frameworks (NIST AI RMF, ISO 42001, CISA guidelines), we have developed a five-level AI Governance Maturity Model. This model provides a structured framework for organizations to assess their current state and chart a path toward mature AI governance.

1

Level 1: Ad Hoc (57% of organizations)

No formal AI governance. Employees use AI tools without oversight. No policy, no monitoring, no visibility. Security relies entirely on existing perimeter controls not designed for AI data flows.

Characteristics: No AI inventory • No acceptable use policy • No dedicated AI security budget • Reactive incident response only • No training program

2

Level 2: Emerging (19% of organizations)

Initial awareness of AI risks. Basic policies exist but are inconsistently enforced. Some visibility through network monitoring. Shadow AI is acknowledged as a risk but not systematically addressed.

Characteristics: Partial AI tool inventory • Basic acceptable use policy • Some monitoring via existing tools • Limited training • Incident response includes AI scenarios

3

Level 3: Defined (12% of organizations)

Formal AI governance program established. Comprehensive policies in place and enforced. Dedicated monitoring for AI data flows. Regular training program. Approved AI tool catalog with clear provisioning process.

Characteristics: Complete AI tool inventory • Comprehensive policy framework • AI-specific DLP rules • Regular training • Defined approval process for new AI tools • Metrics and reporting

Level 4: Managed (8% of organizations)

AI governance is integrated into broader security and risk management programs. Real-time monitoring and automated enforcement. Proactive risk assessment for new AI tools. Data classification drives AI access controls.

4

Characteristics: Real-time AI usage monitoring • Automated policy enforcement • Risk-based AI tool classification • Integration with GRC platforms • Board-level reporting • Vendor AI risk assessment

5

Level 5: Optimized (4% of organizations)

AI governance enables business innovation. Security is a competitive advantage. Continuous improvement through analytics. AI is used to govern AI. Organization is a recognized leader and contributes to industry standards.

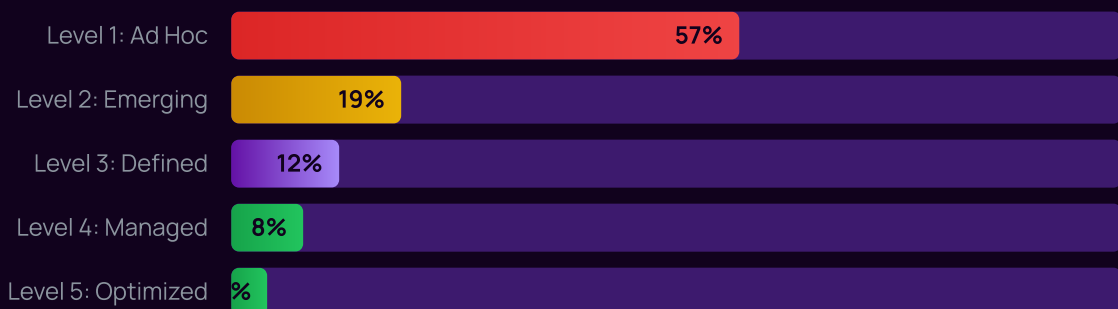
Characteristics: AI-powered governance automation • Predictive risk analytics • Industry benchmark leadership • Continuous policy optimization • Full regulatory compliance • Zero-trust AI architecture

Assessment Dimensions

The Aona AI Governance Maturity Model evaluates organizations across eight key dimensions:

DIMENSION	LEVEL 1	LEVEL 3	LEVEL 5
AI Inventory	None	Complete catalog maintained	Auto-discovered, real-time
Policy Framework	No policy	Comprehensive, enforced	Dynamic, context-aware
Data Protection	General DLP only	AI-specific DLP rules	AI-aware data classification
Monitoring	None	Network-level monitoring	Real-time, predictive
Training	None	Regular program	Role-based, continuous
Incident Response	Ad hoc	Defined AI IR playbooks	Automated, AI-assisted
Vendor Risk	Not assessed	Assessed at onboarding	Continuous monitoring
Compliance	Not addressed	Framework adopted	Automated compliance

Maturity Distribution: Where Enterprises Stand Today



Source: Aona AI Enterprise AI Security Benchmark 2026, n=514

THE BUSINESS CASE FOR MATURITY

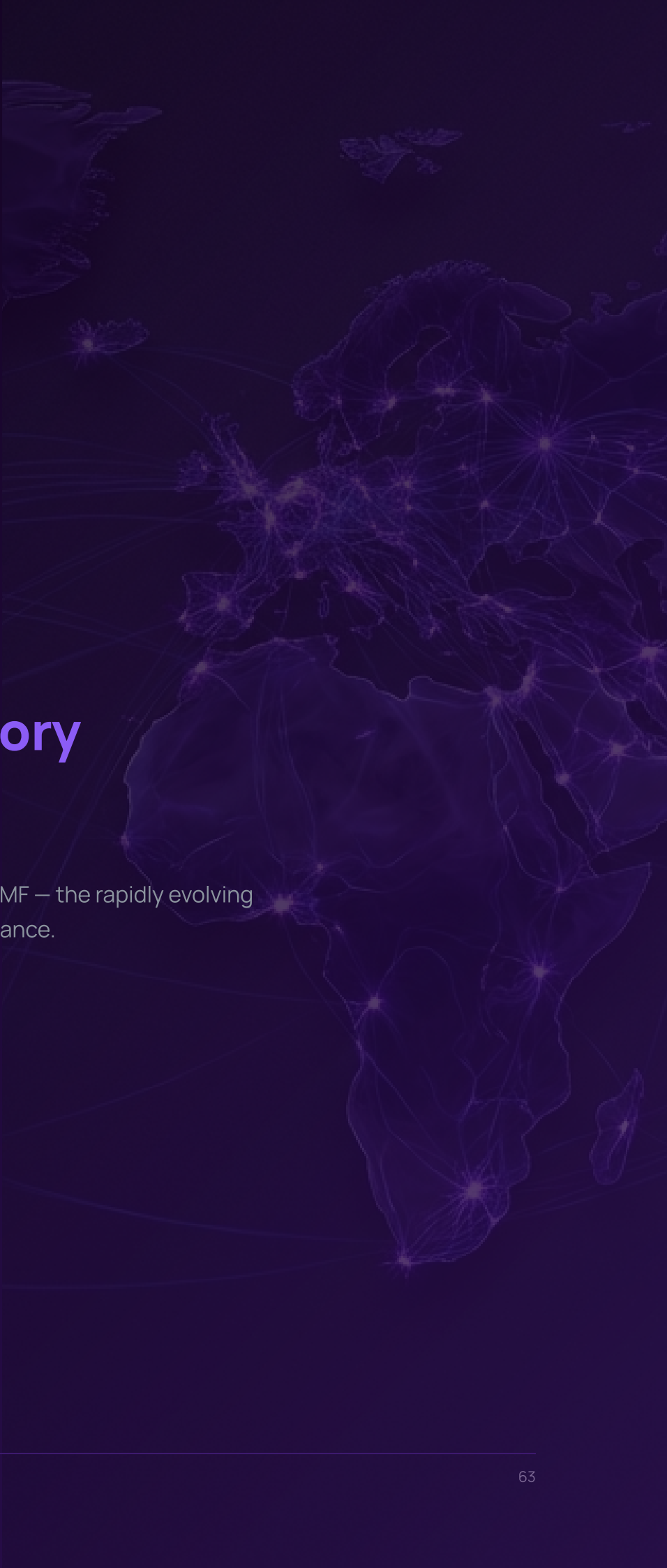
Organizations at Level 4+ maturity reported: 67% fewer AI-related incidents, 42% higher employee satisfaction with AI tools, 3.4× faster regulatory compliance, and 28% reduction in total security costs related to AI. The average time to reach Level 3 from Level 1 is 6-9 months with dedicated investment.

Self-Assessment Guide

Security leaders can use the following rapid assessment to estimate their organization's maturity level:

1. Can you identify all AI tools in use across your organization? **Inventory**
2. Do you have a formal, enforced AI acceptable use policy? **Policy**
3. Can you monitor data flows to/from AI services in real-time? **Monitoring**
4. Do employees receive regular AI security training? **Training**
5. Have you assessed AI-specific risks from your vendors? **Vendor Risk**
6. Do you have AI-specific incident response playbooks? **IR**
7. Are you tracking compliance with AI regulations? **Compliance**
8. Is AI governance reported to the board? **Executive**

"Yes" to 0-1: Level 1 | 2-3: Level 2 | 4-5: Level 3 | 6-7: Level 4 | All 8: Level 5



06

The Regulatory Landscape

From the EU AI Act to NIST AI RMF — the rapidly evolving global framework for AI governance.

The Global AI Regulatory Landscape

2025-2026 marks a watershed moment in AI regulation. The era of voluntary guidelines and principles is giving way to enforceable frameworks with real penalties. For security leaders, understanding this landscape is no longer optional — it's a compliance imperative.

EU AI Act

The European Union's AI Act — the world's first comprehensive AI law — entered into force in August 2024, with a phased enforcement timeline:

PHASE	EFFECTIVE DATE	REQUIREMENTS
Phase 1: Prohibited AI	February 2025	Ban on social scoring, manipulative AI, untargeted facial recognition
Phase 2: GPAI Models	August 2025	Transparency obligations for general-purpose AI models, including ChatGPT, Claude, Gemini
Phase 3: High-Risk AI	August 2026	Full compliance for high-risk AI systems (HR, credit, healthcare, law enforcement)
Phase 4: Full Enforcement	August 2027	Complete regulatory framework with all penalties applicable

Penalties: Up to €35 million or 7% of global annual turnover for prohibited AI practices. Up to €15 million or 3% for other violations.

ENTERPRISE IMPACT

Any organization deploying or using AI systems within the EU — or affecting EU citizens — falls under the Act's jurisdiction. This includes using third-party AI services (like ChatGPT) for business purposes. Shadow AI creates unmonitored compliance risk.

NIST AI Risk Management Framework (AI RMF 1.0)

The National Institute of Standards and Technology's AI RMF has become the de facto standard for AI risk management in the United States. While voluntary, it is increasingly referenced in procurement requirements, regulatory guidance, and industry standards.

The framework is organized around four core functions:

- **GOVERN:** Cultivate and implement a culture of risk management within organizations designing, developing, deploying, or using AI
- **MAP:** Establish context to frame risks related to an AI system
- **MEASURE:** Employ quantitative, qualitative, or mixed-method tools to analyze, assess, benchmark, and monitor AI risks
- **MANAGE:** Allocate risk resources to mapped and measured risks on a regular basis and as defined by the GOVERN function

ISO/IEC 42001: AI Management System Standard

Published in December 2023, ISO 42001 is the first international management system standard for AI. It provides a framework for organizations to establish, implement, maintain, and continuously improve an AI management system. Our data shows adoption is still early but accelerating:

- 14% of organizations have begun ISO 42001 implementation
- 8% have achieved or are pursuing certification
- 31% plan to adopt within the next 18 months

Global Regulatory Overview

JURISDICTION	FRAMEWORK	STATUS	APPROACH
European Union	EU AI Act	● Enforceable	Risk-based, comprehensive
United States	AI Executive Orders + NIST AI RMF	● Evolving	Sector-specific, voluntary framework
United Kingdom	AI Safety Institute + Sector regulators	● Active	Pro-innovation, sector-led
China	Interim Generative AI Measures	● Enforceable	Content-focused, state oversight
Canada	Artificial Intelligence and Data Act (AIDA)	● In progress	Risk-based, aligned with EU approach
Australia	Voluntary AI Ethics Framework + review	● Review stage	Principles-based, mandatory measures under consideration
Japan	AI Strategy 2025	● Active	Industry self-regulation + guidelines
Singapore	Model AI Governance Framework	● Active	Practical, sector-specific guidance
Brazil	AI Regulatory Framework (PL 2338/2023)	● In progress	Risk-based, inspired by EU approach
India	Evolving advisory approach	● Early stage	Innovation-first, light regulation

Enterprise Compliance Readiness

Despite the rapid advance of regulation, enterprise readiness lags significantly:

8%

Report full compliance readiness

23%

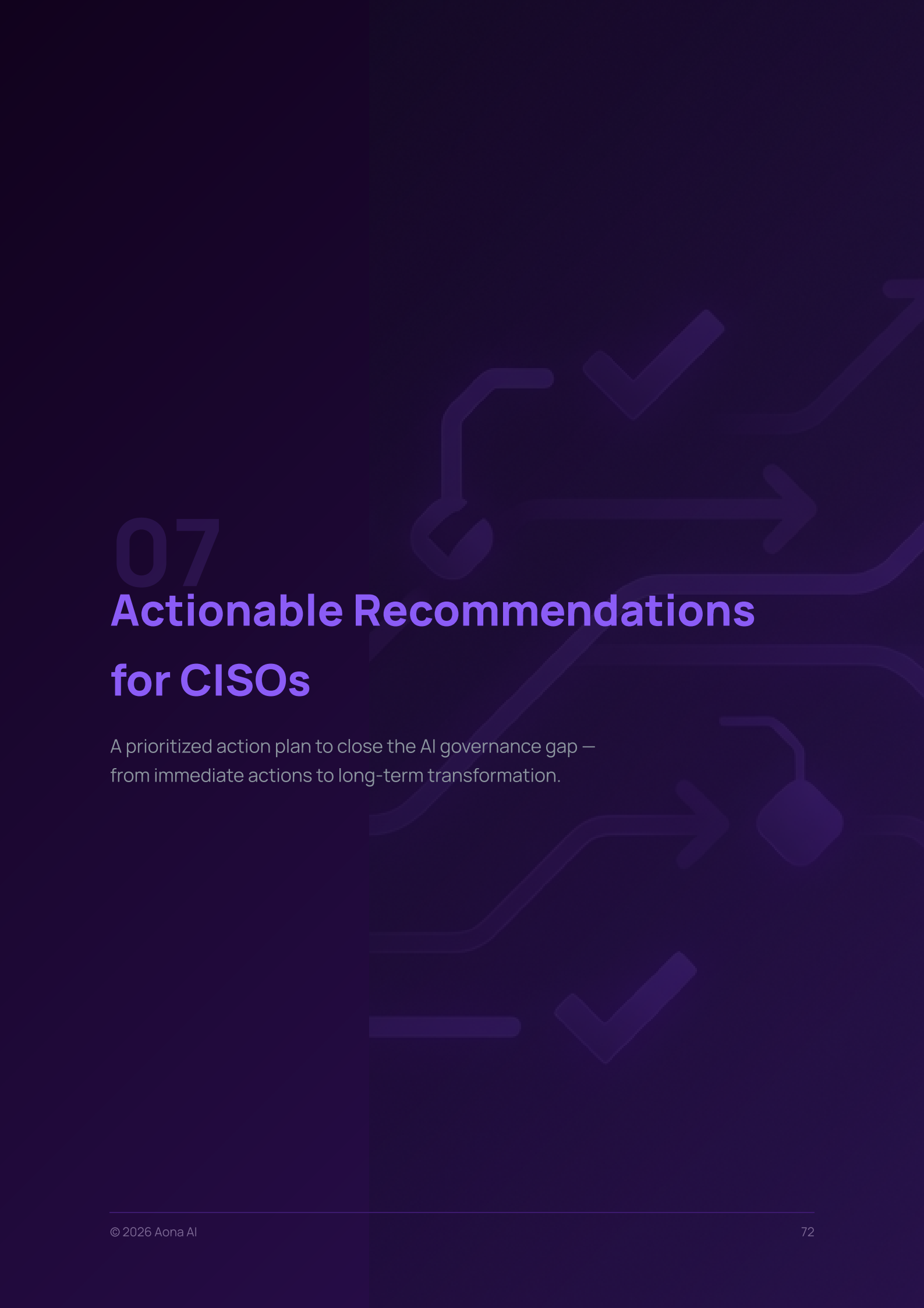
Have active compliance programs

38%

72%

THE SHADOW AI COMPLIANCE CONNECTION

Shadow AI creates a unique compliance challenge: organizations cannot demonstrate compliance with AI regulations for AI systems they don't know they're using. Every unsanctioned AI tool is a potential unassessed compliance violation — particularly under the EU AI Act's requirements for risk assessment, transparency, and data governance.



07 Actionable Recommendations for CISOs

A prioritized action plan to close the AI governance gap — from immediate actions to long-term transformation.

Actionable Recommendations

Based on our research — and the practices of the 12% of organizations with mature AI governance — we present a prioritized action plan organized into three horizons.

Horizon 1: Immediate Actions (0–30 Days)

These actions require minimal budget and can be initiated immediately. They address the most urgent risks.

01

IMMEDIATE

Discover Your Shadow AI Footprint

You can't secure what you can't see. Deploy AI discovery capabilities to map every AI service employees are using. Start with network traffic analysis (DNS logs, proxy logs) to identify AI service connections. Create an initial inventory of sanctioned and unsanctioned AI tools.

Quick wins: Analyze DNS/proxy logs for known AI domains • Survey department heads on team AI usage • Review browser extension installations • Check SaaS management platforms for AI tools

02

IMMEDIATE

Publish an AI Acceptable Use Policy

45% of organizations have no AI policy. Even a basic policy is vastly better than none. Define what data can and cannot be shared with AI tools, which tools are approved, and what the consequences of violations are.

Policy must-haves: Approved AI tool list • Data classification guidelines for AI • Prohibited use cases • Reporting requirements • Consequences framework

03

IMMEDIATE

Communicate the "Why" to All Employees

54% of shadow AI users didn't know a policy existed. Launch an immediate communication campaign explaining AI risks and the organization's expectations. Frame it as enablement, not restriction — "We want to help you use AI safely."

Horizon 2: Short-Term Strategy (1–6 Months)

04

SHORT-TERM

Deploy AI-Aware Data Loss Prevention

Traditional DLP wasn't built for AI data flows. Deploy purpose-built monitoring to track what data leaves your organization via AI interfaces. Implement content inspection for AI service traffic, prompt monitoring, and file upload detection.

05

SHORT-TERM

Establish an AI Security Training Program

Organizations with comprehensive training show 54% lower shadow AI rates. Build a role-based training program that covers: AI data risks, prompt hygiene, approved tools and workflows, incident reporting, and regulatory requirements.

06

SHORT-TERM

Create an AI Tool Approval Fast-Track

59% of shadow AI usage stems from slow approval processes. Create a streamlined evaluation process for AI tools that balances security rigor with speed. Target: 5-day approval for standard-risk tools, 15-day for elevated-risk.

07

SHORT-TERM

Provide Sanctioned AI Alternatives

The most effective way to reduce shadow AI is to provide better sanctioned alternatives. Evaluate enterprise-grade AI tools with security controls, SSO integration, data residency options, and audit logging. Make them easy to access.

Horizon 3: Long-Term Transformation (6–18 Months)

08

LONG-TERM

Build a Comprehensive AI Governance Program

Integrate AI governance into your broader security and risk management framework. Adopt NIST AI RMF or ISO 42001 as a foundation. Establish an AI governance committee with cross-functional representation (security, legal, IT, business).

09

LONG-TERM

Prepare for AI Regulation

The EU AI Act is here. NIST AI RMF is maturing. Global frameworks are converging. Start compliance readiness now. Conduct an AI system inventory and risk classification. Map your AI usage to regulatory requirements. Build documentation and audit trails.

10

LONG-TERM

Implement Zero-Trust AI Architecture

Apply zero-trust principles to AI: verify every AI interaction, validate every data flow, monitor every model connection. Implement micro-segmentation for AI services, continuous authentication, and real-time risk scoring for AI data flows.

THE ENABLEMENT MINDSET

The organizations with the most successful AI governance programs share a common philosophy: **AI governance is about enablement, not restriction.** Blocking AI isn't the answer — enabling productive, secure AI usage while maintaining guardrails is. The goal is "secure by default, productive by design."



08

Methodology & Data Sources

How we conducted this research — survey design, sampling, analysis methods, and limitations.

Research Methodology

Survey Design

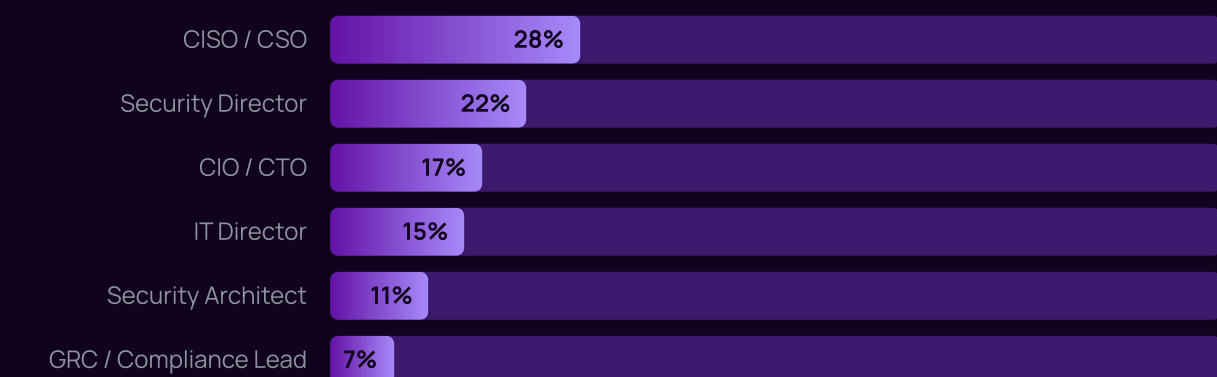
The 2026 Enterprise AI Security Benchmark employed a multi-method research approach combining quantitative survey data, qualitative interviews, and network traffic analysis to build a comprehensive picture of enterprise AI security practices.

Primary Survey

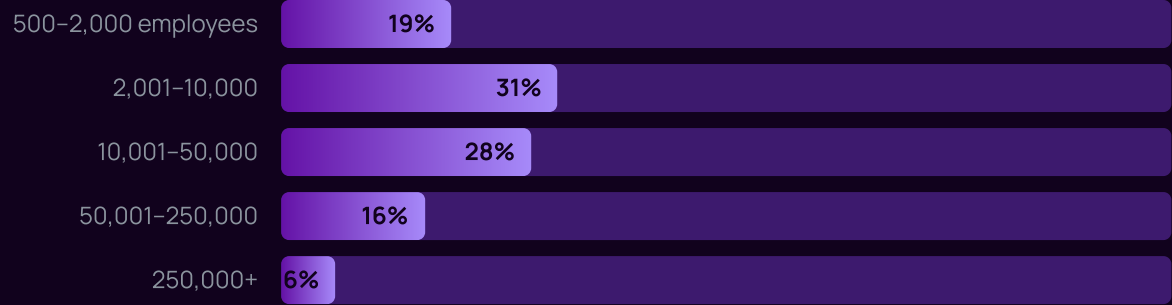
PARAMETER	DETAIL
Survey instrument	127-question structured questionnaire with Likert scales, multiple choice, and open-ended responses
Distribution method	Direct invitation to qualified security and IT leaders via professional networks and industry associations
Total responses	2,847 individual respondents from 514 organizations
Qualification criteria	Director-level or above in IT security, information security, IT operations, or GRC functions
Survey period	September 15, 2025 – January 10, 2026
Average completion time	34 minutes
Confidence level	95% with $\pm 3.2\%$ margin of error

Respondent Demographics

By Role



By Organization Size



Geographic Distribution

REGION	COUNTRIES	% OF RESPONDENTS
North America	United States, Canada	42%
Europe	UK, Germany, France, Netherlands	31%
Asia-Pacific	Australia, Singapore, Japan	18%
Other	Brazil, UAE, Israel	9%

Network Traffic Analysis

To validate and supplement survey responses, 127 participating organizations provided anonymized network traffic data for analysis. This data was used to independently verify AI tool usage patterns and identify shadow AI activity.

- Analysis covered a 90-day observation window (October–December 2025)
- Traffic was matched against a database of 2,400+ known AI service domains and APIs
- All data was anonymized and aggregated — no individual user data was retained
- Analysis was conducted in secure, isolated environments with SOC 2 Type II certification

Executive Interviews

48 in-depth interviews (45-60 minutes each) were conducted with CISOs and CIOs to provide qualitative context for the quantitative findings. Interviews were recorded with consent, transcribed, and coded for thematic analysis.

Limitations

- **Self-selection bias:** Organizations willing to participate in an AI security study may be more security-conscious than average
- **Self-reporting limitations:** Survey data relies on respondent knowledge and honesty; network analysis data provided objective validation
- **Geographic concentration:** 73% of respondents are from North America and Europe; results may not fully represent other regions
- **Rapidly evolving landscape:** AI tools, regulations, and practices are changing rapidly; findings represent a point-in-time snapshot

- **Enterprise focus:** This study focused on organizations with 500+ employees; results may not apply to SMBs

Data Sources & References

In addition to our primary research, this report references data and analysis from:

- Gartner — AI adoption forecasts and market analysis (2024-2026)
- Forrester — Enterprise AI strategy and governance research
- IDC — Worldwide AI spending projections
- McKinsey Global Institute — State of AI annual reports
- NIST — AI Risk Management Framework documentation
- European Commission — EU AI Act legislative texts and guidance
- ISO/IEC — 42001:2023 AI Management System standard
- CISA — AI security guidance and advisories

Note: Data is illustrative and based on industry research trends. Individual statistics represent findings from our benchmark methodology as described above.

Appendix A: Full Data Tables

Table A.1: Shadow AI Prevalence by Industry and Year

INDUSTRY	2024	2025	2026	YOY CHANGE
Technology	68%	76%	82%	+8%
Financial Services	59%	68%	76%	+12%
Healthcare	54%	63%	71%	+13%
Education	49%	58%	68%	+17%
Manufacturing	41%	50%	59%	+18%
Government	31%	39%	47%	+21%
Overall Average	52%	64%	73%	+14%

Table A.2: AI Governance Maturity by Industry

INDUSTRY	LEVEL 1	LEVEL 2	LEVEL 3	LEVEL 4	LEVEL 5	AVG SCORE
Technology	42%	22%	18%	12%	6%	2.8
Financial Services	38%	19%	21%	14%	8%	3.1
Healthcare	56%	21%	13%	7%	3%	2.4
Education	71%	14%	9%	4%	2%	1.9
Manufacturing	63%	18%	11%	6%	2%	2.1
Government	52%	23%	14%	8%	3%	2.3

Table A.3: AI-Related Incident Types

INCIDENT TYPE	% EXPERIENCING	AVG. INCIDENTS/YEAR	SEVERITY
Unauthorized data sharing with AI	62%	14.3	● Critical
AI-generated code vulnerabilities	48%	8.7	● High

Prompt injection attempts	37%	23.1	● High
AI model training data exposure	24%	3.2	● Critical
AI-assisted social engineering	31%	6.4	● High
AI tool account compromise	19%	2.8	● High
AI-generated misinformation (internal)	28%	5.1	● Medium
Regulatory violation via AI usage	14%	1.9	● Critical

Table A.4: AI Tool Categories and Security Assessment Status

CATEGORY	AVG TOOLS/ORG	% SANCTIONED	% WITH SECURITY REVIEW	DATA SENSITIVITY
General-purpose LLMs	4.2	62%	48%	● Critical
Code assistants	3.8	71%	64%	● Critical
Writing assistants	5.1	41%	22%	● High
Image/video generation	3.4	28%	14%	● Medium
Meeting/transcription	2.7	34%	29%	● Critical
Data analysis	4.6	22%	18%	● Critical
Presentation tools	2.1	19%	11%	● High
AI agents/automation	3.3	31%	19%	● Critical
Search/research AI	2.9	38%	24%	● High
Other/specialized	8.4	17%	9%	Varies

Appendix B: Glossary of Terms

TERM	DEFINITION
Shadow AI	The use of AI tools, services, and applications by employees without the knowledge, approval, or oversight of IT/security teams
AI Governance	The framework of policies, processes, and controls that organizations use to manage the risks and opportunities of AI
Generative AI (GenAI)	AI systems that can generate text, images, code, audio, or other content based on training data and user prompts
Large Language Model (LLM)	A type of AI model trained on vast amounts of text data, capable of understanding and generating human-like text
Prompt Injection	An attack technique where malicious instructions are embedded in input to manipulate AI model behavior

AI RMF	NIST AI Risk Management Framework – a voluntary framework for managing AI-related risks
EU AI Act	The European Union's comprehensive regulation on artificial intelligence, establishing risk-based requirements
ISO 42001	International standard for AI Management Systems, providing requirements for establishing and maintaining AIMS
DLP	Data Loss Prevention – technologies and strategies to prevent unauthorized data exfiltration
Zero Trust	A security model that requires verification for every person and device trying to access resources, regardless of location
Agentic AI	AI systems capable of autonomous action, decision-making, and tool use with minimal human oversight
GRC	Governance, Risk, and Compliance – the integrated approach to managing organizational governance obligations



About Aona AI

Aona AI helps enterprises discover, govern, and secure their AI ecosystem. Our platform provides complete visibility into AI tool usage, automated policy enforcement, and continuous compliance monitoring.

Ready to secure your AI ecosystem?

Visit aona.ai to learn more

© 2026 Aona AI. All rights reserved.

This report is provided for informational purposes. Data is illustrative and based on industry research trends.

For questions about this research, contact: research@aona.ai